



Securitatea Platformei Intranet

ICMPP - Institutul de Chimie Macromoleculară 'Petru Poni'

CONDREA CODRIN IOAN

Aprilie 2026





Cuprins

- 1 Ce este Platforma Intranet?
- 2 Tehnologia din spatele platformei
- 3 WordPress vs. Platforma noastră
- 4 Baza de date - Ce este și unde se află?
- 5 Row Level Security (RLS)
- 6 Autentificare și Control Acces
- 7 Criptarea datelor - TLS 1.3
- 8 Protecția datelor personale (GDPR)
- 9 Monitorizare și Alerte în Timp Real
- 10 Protecția împotriva atacurilor
- 11 Răspuns la incidente de securitate
- 12 IRIS - Asistentul AI
- 13 Ce înseamnă AI, LLM, Claude?
- 14 Avantajele platformei - Rezumat



Ce este Platforma Intranet?

O aplicație web internă pentru angajații ICMPP

Un birou digital securizat

accesibil de pe orice calculator sau telefon, 24/7.

- ✓ Gestionare concedii
- ✓ Documente HR
- ✓ Comunicare internă (Chat)
- ✓ Inventar echipamente
- ✓ Anunțuri și evenimente
- ✓ Bibliotecă digitală



Analogie

Imaginați-vă un birou fizic cu pază la intrare, camere de supraveghere, și fiecare sertar are cheie individuală. Platforma noastră este versiunea digitală a acestui birou.



Cu ce este construită platforma?

React

(User Interface Library)

Bibliotecă JavaScript pentru interfețe - creează pagini web rapide și interactive.

TypeScript

(Typed Programming Language)

Limbaj de programare cu verificare de tipuri - previne erorile înainte să apară.

Supabase

(Backend-as-a-Service)

Platformă cloud pentru baze de date, autentificare și funcții server - certificată SOC2.

Edge Functions

(Serverless Functions)

Funcții server care rulează aproape de utilizator - pentru operații securizate.

Toate componentele sunt open-source, auditate și actualizate constant.



WordPress vs. Platforma noastră

WordPress

✗ 43% din site-urile hackuite în 2024

✗ 60.000+ plugin-uri terțe (nesecurizate)

✗ Bază de date MySQL fără RLS

✗ Atacuri automatizate cunoscute (bots)

✗ Actualizări frecvente obligatorii

✗ Oricine poate vedea că e WordPress

Platforma ICMP

✓ Cod custom - suprafață de atac minimă

✓ Zero plugin-uri terțe nesecurizate

✓ PostgreSQL cu Row Level Security

✓ Nu este vizibilă pentru roboți web

✓ Arhitectură modernă, stabilă

✓ Tehnologie ascunsă atacatorilor



Baza de date - Ce este și unde se află?

PostgreSQL (baza noastră)

- ✓ Criptare AES-256 la repaus (ca un seif bancar)
- ✓ Criptare TLS 1.3 în tranzit (date călătoresc sigilate)
- ✓ Row Level Security - fiecare user vede doar datele sale
- ✓ Administrat de Supabase (SOC2, ISO 27001)
- ✓ Backup automat zilnic
- ✓ Servere în UE (GDPR compliant)

MariaDB / MySQL (clasic)

- ✗ Criptare disponibilă dar rareori activată
- ✗ TLS opțional, adesea dezactivat
- ✗ Fără Row Level Security nativ
- ✗ Administrat manual de fiecare organizație
- ✗ Backup manual sau cu scripturi
- ✗ De obicei pe server local, fără certificări

Analogie: PostgreSQL cu Supabase = seif bancar digital | MariaDB clasic = dulap cu lacăt



Row Level Security (RLS) - explicat simplu

Ce este RLS?

Row Level Security = Securitate la Nivel de Rând

Fiecare utilizator vede DOAR datele sale:

Ana (HR)

Vede: Toate dosarele HR

🔓 Acces extins (rolul HR)

Ion (Angajat)

Vede: Doar dosarul său

🔒 Acces restricționat

Maria (Angajat)

Vede: Doar dosarul său

🔒 Acces restricționat

Chiar dacă cineva accesează baza de date, NU poate vedea datele altor utilizatori.



Autentificare și Control Acces

Sistem de Roluri

Super Admin, HR, Șef Departament, Angajat - fiecare rol are permisiuni stricte

Parole verificate HIBP

Parolele sunt verificate contra a 700+ milioane de parole sparte cunoscute (Have I Been Pwned)

2FA / MFA

Autentificare în doi pași (Two-Factor Authentication) - pe lângă parolă, e nevoie de un cod din telefon

Reautentificare

Pentru acțiuni critice (ștergere cont, modificare roluri) se cere din nou parola

Sesiuni Active

Administratorii pot vedea toate sesiunile active și pot face logout global



Criptarea Datelor - TLS 1.3

Transport Layer Security - Protocol de Securitate a Transportului

❑ **Fără criptare**

= Carte poștală

Oricine pe drum poate citi mesajul. Datele circulă 'în clar' - parole, documente, informații personale vizibile.

❑ **Cu TLS 1.3**

= Scrisoare sigilată

Nimeni nu poate citi conținutul în tranzit. Datele sunt transformate în cod imposibil de descifrat fără cheia corectă.

Platforma ICMPP folosește TLS 1.3 - cel mai nou și mai sigur protocol disponibil în 2026.

Protecția Datelor Personale (GDPR)

GDPR = General Data Protection Regulation (Regulamentul General privind Protecția Datelor)

Mascarea automată a datelor sensibile:

CNP	2901234567890	→	29012XXXXX890
-----	---------------	---	---------------

Serie CI	XY 123456	→	XX XXXXXX
----------	-----------	---	-----------

Telefon	0740 123 456	→	07XX XXX X56
---------	--------------	---	--------------

Cine poate vedea datele complete?

Doar utilizatorii cu rol HR sau Super Admin pot demasca datele. Toate accesările sunt înregistrate în jurnalul de audit.



Monitorizare și Alerte în Timp Real

Security Dashboard

Panou centralizat cu toate evenimentele de securitate - login-uri eșuate, dispozitive noi, IP-uri suspecte

Notificări Telegram

Alerte automate pe Telegram când apar evenimente critice - atacuri, mentenanță, cereri de cont

Jurnal de Audit Complet

Fiecare acțiune este înregistrată: CINE a făcut CE, CÂND, și DE UNDE (IP, dispozitiv, rol)

Evenimente Securitate

Tabel dedicat: failed_login, new_device, suspicious_ip, data_export, role_change

Toate alertele sunt trimise în < 5 secunde de la detectare.



Protecția împotriva atacurilor

CSP

Content Security Policy

Controlează ce scripturi pot rula pe pagină - blochează injecția de cod malițios

CORS

Cross-Origin Resource
Sharing

Doar site-ul ICMPP poate comunica cu serverul - blochează cereri din alte site-uri

Rate Limiting

Limitarea ratei cererilor

Dacă cineva trimite prea multe cereri (atac brute-force), este blocat automat

IP Filtering

Filtrare adresă IP

Acces doar din rețeaua institutului sau de pe dispozitive aprobate

HIBP Check

Have I Been Pwned

La fiecare autentificare, parola este verificată contra bazelor de parole compromise

5 straturi de protecție active simultan - 'apărare în adâncime' (Defense in Depth)



Ce se întâmplă în caz de atac hacker?

1

Detectare automată

Sistemul identifică activitate suspectă (login-uri multiple eșuate, IP necunoscut)



2

Alertă Telegram instant

Administratorii primesc notificare pe telefon în câteva secunde



3

Blocare automată IP

Adresa IP atacatorului este blocată imediat



4

Logout global

Toate sesiunile suspecte sunt terminate automat



5

Investigare & Audit

Jurnalul complet permite analiza detaliată a evenimentului



IRIS - Asistentul AI al platformei

IRIS este un asistent inteligent integrat în platformă care ajută angajații cu întrebări și sarcini.

Cum este securizat IRIS?

Rate Limiting	Maximum 20 cereri / minut per utilizator - previne abuzul
Clasificare acțiuni	Acțiunile sunt clasificate în 'citire' si 'scriere' - operațiile de scriere necesită confirmare
Blocare comenzi necunoscute	IRIS nu poate executa operații necunoscute sau periculoase
Erori sanitizate	Mesajele de eroare nu expun detalii tehnice sau structura internă

IRIS folosește tehnologia Claude AI (Anthropic) - cel mai sigur model de limbaj din industrie.

Ce înseamnă AI, LLM și Claude?

AI

Artificial Intelligence
Inteligență Artificială

Programe de calculator care pot învăța din date și lua decizii - similar cum un om învață din experiență.

LLM

Large Language Model
Model de Limbaj de Mari Dimensiuni

Un program antrenat pe milioane de texte din internet care poate înțelege și genera limbaj uman natural.

Claude

Creat de Anthropic (SUA)
Focusat pe siguranță

Un model AI conceput special să fie sigur, onest și util. Compania Anthropic prioritizează siguranța AI.

Analogie: Claude este ca un asistent foarte citit care răspunde la întrebări - dar nu 'gandeste' ca un om.

Avantajele platformei - Rezumat

Securitate multi-strat

5+ niveluri de protecție
active simultan

Date criptate

AES-256 la repaus + TLS
1.3 în tranzit

Monitorizare 24/7

Security Dashboard +
alerte automate

Alerte instant

Notificări Telegram în < 5
secunde

GDPR compliant

Mascare date, servere UE,
jurnalizare

Fără plugin-uri vulnerabile

Cod custom, zero
dependențe riscante

Backup automat

Copii zilnice ale bazei de
date

Acces controlat

Roluri, RLS, 2FA,
reautentificare



Concluzie

Platforma Intranet ICMPP este construită cu cele mai noi standarde de securitate din 2026.

Datele dumneavoastră sunt protejate prin:
criptare de nivel bancar, control strict al accesului,
monitorizare permanentă și răspuns automat la incidente.



Întrebări?

CONDREA CODRIN IOAN

Institutul de Chimie Macromoleculară 'Petru Poni'
Iași, România

